

SIEM Telemetrisi ve Tehdit İstihbaratı Kullanılarak Açıklanabilir Graf Tabanlı Saldırı Yüzeyi Görünürlük Skorlaması

İsmet Arslan
Bilgisayar Mühendisliği Bölümü
[Üniversite / Kurum Adı]
[Şehir], Türkiye
[e-posta adresi veya ORCID]

Özet—Güvenlik operasyon merkezleri uç nokta, ağ, kimlik ve uygulama katmanlarından heterojen telemetri toplamaktadır; ancak birçok kurum hâlâ saldırı yüzeyinin ne kadarının izlenebilir olduğunu ölçülebilir biçimde ortaya koymakta zorlanmaktadır. Bu çalışma, SIEM telemetrisi, varlık envanteri, siber tehdit istihbaratı (CTI) ve MITRE ATT&CK teknik eşleştirmelerini tek bir graf tabanlı modelde birleştiren açıklanabilir bir saldırı yüzeyi görünürlük skorlama yaklaşımı önermektedir. Önerilen model; log kapsama oranı, kritik varlık görünürlüğü, MITRE teknik kapsamı, CTI zenginleştirme düzeyi ve telemetri güncelliği gibi metrikleri ağırlıklı bir görünürlük skoruna dönüştürmektedir. Modelin amacı yalnızca sayısal bir skor üretmek değil, aynı zamanda skorun neden yükseldiğini veya düştüğünü açıklayan kanıt dayalı bulgular üretmektir. Wazuh tabanlı kontrollü bir laboratuvar senaryosu üzerinde sentetik ve anonimleştirilmiş verilerle kavram kanıtı değerlendirilmesi sunulmuştur. Ön sonuçlar, graf tabanlı veri füzyonunun SOC ekipleri için izleme boşluklarını, zayıf telemetri alanlarını ve öncelikli iyileştirme ihtiyaçlarını anlaşılır şekilde gösterebildiğini ortaya koymaktadır.

Anahtar Kelimeler—SIEM, Wazuh, saldırı yüzeyi, tehdit istihbaratı, MITRE ATT&CK, graf modeli, açıklanabilir güvenlik, SOC olgunluğu

I. GİRİŞ

Modern güvenlik operasyon merkezleri (Security Operations Center, SOC), zararlı davranışları tespit etmek, olayları incelemek ve müdahale faaliyetlerini önceliklendirmek için sürekli telemetri toplamaya dayanır. Güvenlik bilgisi ve olay yönetimi (SIEM) sistemleri bu telemetrinin merkezileştirilmesini sağlar; ancak yalnızca olay toplamak, kurumun gerçekten ne kadar görünürlüğe sahip olduğunu göstermeye yetmez. Bir varlıktan log geliyor olması, ilgili saldırı tekniklerinin izlenebildiği, kritik sistemlerin kapsandığı veya tehdit istihbaratı bağlamının kullanılabilirdiği anlamına gelmeyebilir.

Bu problem, kurumsal saldırı yüzeylerinin büyümesiyle daha belirgin hale gelmektedir. Bulut servisleri, uzaktan erişim platformları, kimlik sağlayıcıları, uç noktalar ve üçüncü taraf entegrasyonları saldırganlar için çok sayıda yol oluşturur. SOC ekipleri bu varlıkların hangilerinden taze telemetri geldiğini, hangi MITRE ATT&CK teknikleri için algılama görünürlüğü bulunduğunu ve hangi alarmların CTI ile zenginleştirildiğini hızlı şekilde görebilmelidir. Bu nedenle saldırı yüzeyi görünürlüğünün ölçülmesi, yalnızca uyumluluk veya envanter yönetimi değil, doğrudan operasyonel güvenlik ihtiyacıdır.

Bu çalışma şu araştırma sorusuna odaklanmaktadır: Heterojen SIEM telemetrisi ve tehdit bağlamı, saldırı yüzeyi görünürlüğünü temsil eden açıklanabilir bir skora nasıl dönüştürülebilir? Bu soruya yanıt vermek için varlıklar, telemetri kaynakları, alarmlar, tehdit göstergeleri ve ATT&CK teknikleri arasında ilişkiler kuran graf tabanlı bir model önerilmektedir. Model, görünürlüğü yalnızca olay sayısı üzerinden değil, telemetrinin kapsamı, güncelliği, kritikliği ve tehdit bağlamıyla ilişkilendirilmesi üzerinden değerlendirmektedir.

Bu bildirinin temel katkısı, parçalı operasyonel telemetriyi yorumlanabilir bir görünürlük indeksine dönüştüren pratik bir skorlama çerçevesi sunmasıdır. Çerçeve, ayrıntılı penetrasyon testi, zafiyet yönetimi veya klasik SOC olgunluk modellerinin yerine geçmeyi amaçlamaz. Bunun yerine, mevcut SIEM verilerinden hareketle kurumun saldırı yüzeyinin ne ölçüde izlenebilir olduğunu ölçmeye yönelik tamamlayıcı bir karar destek katmanı sağlar.

Çalışmanın katkıları üç başlıkta özetlenebilir. Birincisi, varlıkları, SIEM telemetrisini, CTI göstergelerini ve ATT&CK tekniklerini birleştiren bir graf şeması tanımlanmıştır. İkincisi, log kapsama, kritik varlık kapsama, MITRE algılama kapsamı, CTI zenginleştirme ve telemetri güncelliğini bir araya getiren ağırlıklı ve açıklanabilir bir skor önerilmiştir. Üçüncüsü, Wazuh tabanlı sentetik bir laboratuvar senaryosu ile yaklaşımın uygulanabilirliği gösterilmiştir.

II. İLGİLİ ÇALIŞMALAR

A. SIEM Telemetrisi ve Sürekli İzleme

SIEM sistemleri olay toplama, korelasyon ve alarm üretme süreçlerini merkezileştirmek için yaygın olarak kullanılmaktadır. Sürekli izleme yaklaşımı, güvenlik durumunun tek seferlik kontrollerle değil, sistemlerin, kontrollerin ve operasyonel göstergelerin devamlı gözlemlenmesiyle değerlendirilmesi gerektiğini vurgular. Ancak uygulamada SIEM çıktıları çoğunlukla alarm yoğunluğu, kural eşleşmeleri veya olay hacmi üzerinden izlenmektedir. Bu göstergeler önemli olmakla birlikte, izleme kapsamındaki kör noktaları doğrudan ortaya koymakta sınırlı kalabilir.

Wazuh gibi açık kaynak SIEM platformları uç nokta izleme, kural tabanlı tespit ve ATT&CK ilişkili kural metaverisi sağlayabilmektedir. Wazuh dokümantasyonu,

kuralların MITRE tanımlayıcıları içerebildiğini ve bunun alarmların belirli taktik ve tekniklerle ilişkilendirilmesine imkân verdiğini belirtmektedir [2]. Bu özellik, görünürlük analizinin yalnızca varlık veya log düzeyinde değil, saldırı tekniği düzeyinde de yapılabilmesi açısından önemlidir.

B. MITRE ATT&CK ve Tehdit İstihbaratı

MITRE ATT&CK, saldırgan taktik ve tekniklerini yapılandırılmış bir bilgi tabanı olarak sunar ve Windows, Linux, macOS, bulut, kimlik sağlayıcıları, SaaS, ağ cihazları, konteynerler ve endüstriyel kontrol sistemleri gibi farklı platformları kapsar [1]. Bu yapı, algılama kapsamını değerlendirmek ve güvenlik kontrollerini saldırgan davranışlarıyla ilişkilendirmek için yaygın biçimde kullanılmaktadır.

STIX ve TAXII gibi tehdit istihbaratı standartları; göstergeler, zararlı yazılımlar, saldırı örüntüleri ve ilişkili siber tehdit nesnelerinin makine tarafından okunabilir biçimde temsil edilmesini ve paylaşılmasını sağlar [3], [11]. CTI, SIEM alarmlarını IP adresi, alan adı, dosya karması, saldırı tekniği, kampanya veya tehdit aktörü bağlamıyla zenginleştirerek uyarıların önceliklendirilmesine katkı sağlayabilir. Bununla birlikte CTI değerinin operasyonel olarak ölçülmesi için zenginleştirmenin görünürlük skoruna nasıl yansdığı açıkça tanımlanmalıdır.

C. Graf Tabanlı Siber Güvenlik Değerlendirmesi

Siber güvenlik bilgi grafları; varlıkları, olayları, zafiyetleri ve tehdit istihbaratını bir araya getirerek akıl yürütme ve karar destek sağlamak amacıyla incelenmektedir. Siber güvenlikte bilgi grafi kullanımına ilişkin çalışmalar, çok kaynaklı güvenlik verisinin ilişkisel biçimde modellenmesinin tespit, önceliklendirme ve bağlamsal analiz süreçlerini destekleyebileceğini göstermektedir [8].

Mevcut olgunluk ve skor kartı yaklaşımları çoğu zaman uyumluluk, kontrol varlığı veya test sonuçlarına odaklanmaktadır. ATT&CK tabanlı derecelendirme çerçeveleri, güvenlik değerlendirme sonuçlarını teknik kapsama üzerinden özetlemek için önerilmiştir [7]. Bu çalışmada ise odak, üretim ortamından veya kontrollü laboratuvarlardan gelen telemetri kanıtlarının graf üzerinde birleştirilmesi ve kurumun saldırı yüzeyi görünürlüğüne açıklanabilir bir skora dönüştürülmesidir.

III. ÖNERİLEN MODEL

Önerilen model beş mantıksal katmandan oluşmaktadır: varlık envanteri, telemetri alımı, tehdit bağlamı, graf füzyonu ve açıklanabilir skorlama. Şekil 1 veri akışını özetlemektedir. Varlık envanteri kapsam içindeki beklenen sistemleri ve kritikliği sağlar. Telemetri alım katmanı Wazuh uyarıları, Sysmon olayları, kimlik doğrulama logları ve ağ güvenliği logları gibi kaynaklardan kanıt toplar. Tehdit bağlamı katmanı CTI göstergelerini ve ATT&CK eşleştirmelerini içerir. Graf füzyon katmanı bu unsurlar arasındaki ilişkileri kurar. Skorlama katmanı ise ilişkilerden ölçülebilir ve açıklanabilir görünürlük çıktıları üretir.

Graf tabanlı saldırı yüzeyi görünürlük hattı



Şekil 1. Önerilen graf tabanlı görünürlük skorlama hattı.

A. Graf Şeması

Graf $G = (V, E)$ olarak tanımlanır. Burada V düğümleri, E ise tiplenmiş kenarları temsil eder. Düğümler varlıkları, log kaynaklarını, alarmları, göstergeleri, ATT&CK tekniklerini ve tespit kurallarını temsil edebilir. Kenarlar ise observes, maps-to, enriches ve lacks-coverage gibi ilişki tiplerini içerir. Bu ilişkiler, görünürlük skorunun yalnızca olay sayısından değil, güvenlik kanıtları arasındaki bağlardan türetilmesini sağlar.

Önerilen şemada varlık düğümleri uç noktaları, sunucuları, güvenlik duvarlarını, VPN platformlarını, bulut servislerini ve kimlik bileşenlerini temsil eder. Telemetri düğümleri Wazuh alarmlarını, Sysmon olaylarını, kimlik doğrulama loglarını, ağ bağlantı olaylarını veya uygulama loglarını temsil eder. Teknik düğümleri seçili ATT&CK taktik ve tekniklerine karşılık gelir. Tehdit düğümleri ise IOC, zararlı yazılım etiketi, kampanya veya tehdit aktörü gibi CTI nesnelerini ifade eder.

Varlık düğümü: tür, sahip, platform ve kritiklik öz niteliklerine sahip izlenen veya izlenmesi beklenen kurumsal bileşen.

Telemetri düğümü: SIEM, uç nokta, ağ, kimlik veya uygulama kaynaklarından toplanan olay ya da alarm kanıtı.

Teknik düğümü: kural metaverisi, analitik mantık veya gözlenen kanıtlarla ilişkilendirilen ATT&CK taktiği ya da tekniği.

Tehdit düğümü: alarmları zenginleştirmek için kullanılan IOC, zararlı yazılım etiketi veya kampanya referansı gibi CTI nesnesi.

Negatif kanıt: kör noktaları açıklamak için kullanılan eksik, eski veya tamamlanmamış telemetri ilişkisi.

B. Görünürlük Metrikleri

Görünürlük, $[0,1]$ aralığında normalize edilmiş metrikler kullanılarak hesaplanır. V_s olarak gösterilen varsayılan skor ağırlıklı toplam biçiminde hesaplanır:

$$V_s = 100 * (w1LC + w2CAC + w3MDC + w4CTIC + w5TF)$$

Burada LC log kapsama oranını, CAC kritik varlık kapsamını, MDC MITRE algılama kapsamını, CTIC CTI zenginleştirme kapsamını ve TF telemetri güncelliğini temsil eder. Ağırlıklar kurumun risk önceliklerine göre uyarlanabilir. Kavram kanıtlama senaryosunda sırasıyla 0.30, 0.25, 0.20, 0.15 ve 0.10 ağırlıkları kullanılmıştır.

LC: taze log üreten varlıkların kapsam içindeki toplam varlıklara oranı.

CAC: taze telemetriye sahip kritik varlıkların tüm kritik varlıklara oranı.

MDC: kapsanan ATT&CK tekniklerinin seçili teknik alt kümesine oranı.

CTIC: tehdit istihbaratıyla zenginleştirilmiş alarmların uygun alarmlara oranı.

TF: güncellik eşiği içinde kalan telemetri kaynaklarının oranı.

C. Açıklanabilirlik Katmanı

Açıklanabilirlik katmanı, graf kanıtlarını kısa ve anlaşılır bulgulara dönüştürür. Model yalnızca nihai skoru sunmak yerine, skor değişimine neden olan yolları izler. Örneğin kritik bir etki alanı denetleyicisinin taze log üretmemesi durumunda model, varlık düğümünden eksik telemetri kenarına ve ilgili kritik varlık kapsama metriğine kadar izlenebilir bir açıklama oluşturur.

Bu katman deterministik şablonlarla veya yapılandırılmış girdilerle kontrol edilen büyük dil modeli (LLM) yardımıyla uygulanabilir. Bu bildiride LLM kullanımı isteğe bağlı olarak ele alınmıştır. Birincil katkı, açıklamaların graf kanıtına dayalı olarak üretilebilmesidir. Böylece model çıktısı “skor 66.3/100” düzeyinde kalmaz; hangi varlık, hangi telemetri eksikliği ve hangi kapsama boşluğu nedeniyle bu sonucun oluştuğunu da gösterir.

D. Skorlama Süreci

Skorlama süreci deterministik bir işlem hattını takip eder. İlk olarak beklenen izleme kapsamı varlık envanterinden çıkarılır. İkinci olarak her varlık en güncel telemetri kaynağıyla eşleştirilir. Üçüncü olarak alarmlar, ATT&CK teknikleri ve CTI göstergeleriyle ilişkilendirilir. Dördüncü olarak negatif kanıtlar, yani eksik veya eski telemetri ilişkileri oluşturulur. Son olarak metrikler hesaplanır ve en düşük katkıya sahip bileşenlerden açıklamalar üretilir.

Adım 1: Varlık envanterini yükle ve her varlığa tür, kritiklik, sahip ve beklenen telemetri kaynağı ata.

Adım 2: SIEM olaylarını varlık, zaman damgası, kaynak, alarm, kural ve gösterge alanlarına normalize et.

Adım 3: Varlıklar, telemetri, alarmlar, göstergeler ve teknikler için graf düğümleri oluştur.

Adım 4: observes, maps-to, enriches ve lacks-coverage ilişkilerini oluştur.

Adım 5: Graf ilişkilerini kullanarak LC, CAC, MDC, CTIC ve TF metriklerini hesapla.

Adım 6: En düşük katkı veren metriklerden ve negatif kanıt yollarından açıklamalar üret.

IV. KAVRAM KANITLAMA LABORATUVAR TASARIMI

Önerilen modelin hassas üretim verisi kullanılmadan uygulanabilirliğini göstermek için kontrollü bir laboratuvar senaryosu tasarlanmıştır. Ortam, gerçek kurum loglarını değil, sentetik ve anonimleştirilmiş telemetri nesnelerini kullanmaktadır. Laboratuvar mimarisi Wazuh yöneticisi, bir Windows uç noktası, bir Linux sunucusu, sentetik CTI listesi, varlık envanteri CSV dosyası ve ATT&CK eşleştirme dosyasından oluşmaktadır.

Wazuh yöneticisi: merkezi alarm işleme, ajan durum izleme ve kural metaverisi toplama.

Windows uç noktası: süreç oluşturma, DNS sorgusu, ağ bağlantısı ve oturum açma olayları için Sysmon ve güvenlik logu üretimi.

Linux sunucusu: SSH kimlik doğrulama hataları, sudo etkinliği, servis logları ve komut ilişkili telemetri.

Sentetik CTI listesi: zenginleştirme testi için IP adresi, alan adı, hash, teknik ve güven alanları.

Varlık envanteri CSV: varlık türü, kritiklik, iş sahibi, beklenen log kaynağı ve izleme durumu alanları.

ATT&CK eşleştirme dosyası: seçili teknikler, taktikler, platformlar, beklenen veri kaynağı ve tespit kuralı referansları.

A. Telemetri Üretimi

Windows telemetrisi süreç oluşturma, ağ bağlantısı, DNS sorgusu, başarısız oturum açma ve PowerShell çalıştırma olaylarıyla temsil edilmiştir. Linux telemetrisi SSH kimlik doğrulama hataları, ayrıcalıklı komut çalıştırma ve servis loglarıyla temsil edilmiştir. Ayrıca basit IOC eşleşmeleri ve ATT&CK teknik eşleştirmeleri oluşturularak CTI zenginleştirme ve algılama kapsama metriklerinin hesaplanması sağlanmıştır.

Laboratuvar senaryosu kasıtlı kör noktalar da içermektedir. Bazı varlıklar envantere bulunmasına rağmen güncel log üretmemektedir. Bir kritik sunucu, son görülme zaman damgası belirlenen güncellik eşiğinin dışında olduğu için eski telemetriye sahip olarak işaretlenmiştir. Bazı uyarılar CTI ile zenginleştirilirken bazıları zenginleştirilmemiştir. Böylece modelin hem pozitif hem negatif kanıt üretmesi sağlanmıştır.

B. Veri İşleme Hattı

İşlem hattı, varlık envanteri ve telemetrinin ortak bir tablo yapısına normalize edilmesiyle başlar. Her varlığa tanımlayıcı, tür, kritiklik düzeyi ve beklenen telemetri kaynakları atanır. Alarmlar zaman damgası, kaynak, kural kimliği, teknik kimliği ve gösterge alanlarıyla etiketlenir. Ardından bu tablolar graf düğümlerine ve kenarlarına dönüştürülür.

Normalize edilmiş tablolar graf kenarlarına çevrilir. Güncel Wazuh ajan durumuna sahip bir varlık ilgili telemetri kaynağına observes kenarı alır. Teknik tanımlayıcısı içeren bir alarm ATT&CK tekniğine maps-to kenarıyla bağlanır. IOC eşleşmesi içeren alarm CTI nesnesine enriches kenarıyla bağlanır. Beklenen fakat güncel olmayan kaynaklar için lacks-coverage kenarları oluşturulur.

V. ÖN SONUÇLAR VE TARTIŞMA

Kavram kanıtlama senaryosu dört kritik varlık dâhil olmak üzere toplam on varlık içermektedir. Yedi varlık en az bir güncel telemetri kaynağına sahipken üç varlık eksik veya eski telemetriye sahiptir. Seçili ATT&CK alt kümesi sekiz teknikten oluşmaktadır ve bunların beşi görünür kabul edilmiştir. Uygun alarmların %40'ı CTI ile zenginleştirilmiştir.

Log kapsama oranı: 0.70 ve ağırlıklı katkı 0.210.

Kritik varlık kapsamı: 0.75 ve ağırlıklı katkı 0.188.

MITRE algılama kapsamı: 0.625 ve ağırlıklı katkı 0.125.

CTI zenginleştirme kapsamı: 0.40 ve ağırlıklı katkı 0.060.

Telemetri güncelliği: 0.80 ve ağırlıklı katkı 0.080.

Nihai görünürlük skoru: sentetik kavram kanıtlama senaryosunda 66.3/100.

Nihai görünürlük skoru, sentetik senaryoda orta düzeyde bir izleme durumuna işaret etmektedir. Skor düşük değildir; çünkü varlıkların çoğu en az bir telemetri kaynağı

üretmektedir. Ancak skor yüksek de değildir; çünkü üç varlıkta güncel log bulunmamakta, bir kritik varlıkta telemetri eski kalmakta, CTI zenginleştirme oranı sınırlı kalmakta ve seçili ATT&CK tekniklerinin tamamı kapsanmamaktadır.

Graftan üretilen örnek açıklama şu şekildedir: “Görünürlük skoru düşmektedir; çünkü üç varlık güncel log üretmemektedir, bunlardan biri kritiktir, uygun alarmların yalnızca %40’ı CTI ile zenginleştirilmiştir ve üç seçili ATT&CK tekniği için görünürlük bulunmamaktadır.” Bu açıklama, skurun operasyonel aksiyona dönüştürülebilmesini sağlar.

Model çeşitli SOC kullanım senaryolarını destekleyebilir. İlk olarak, olay gerçekleşmeden önce izleme boşluklarını ortaya çıkarmak için haftalık görünürlük sağlık kontrolü olarak kullanılabilir. İkinci olarak, yeni log kaynaklarının veya ajanların önceliklendirilmesine yardımcı olabilir. Üçüncü olarak, teknik ekipler ve yöneticiler arasında ortak bir görünürlük dili sağlayabilir. Dördüncü olarak, CTI kaynaklarının alarm zenginleştirmeye gerçek katkısını ölçmek için kullanılabilir.

A. Sınırlılıklar

Mevcut kavram kanıtlama çalışmasının sınırlılıkları vardır. Değerlendirme, üretim telemetrisi yerine sentetik ve küçük ölçekli bir laboratuvar senaryosu kullanmaktadır. Bu nedenle sayısal değerler evrensel bir güvenlik seviyesi olarak yorumlanmamalıdır. Değerler, önerilen skorlama mantığının nasıl çalıştığını göstermek amacıyla kullanılmıştır.

Diğer bir sınırlılık, doğru varlık envanteri ve eşleştirme tablolarına duyulan bağımlılıktır. Bir kurum varlık kritikliğini veya beklenen telemetri kaynaklarını güncel tutmuyorsa, model eksik veya yanıltıcı görünürlük sonuçları üretebilir. Gelecek çalışmalarda daha büyük laboratuvar ortamları, gerçek zamanlı veri akışı ve farklı SIEM platformlarıyla karşılaştırmalı değerlendirme yapılması planlanmaktadır.

VI. UYGULAMA NOTLARI

Önerilen model küçük bir Python işleme katmanı ile uygulanabilir. Varlık envanteri ve eşleştirme dosyaları CSV veya JSON biçiminde tutulabilir. Wazuh alarmları ise API, OpenSearch sorguları veya dışa aktarılan olay dosyaları üzerinden alınabilir. Graf yapısı NetworkX, Neo4j veya benzeri bir graf işleme aracıyla oluşturulabilir. Skorlama sonuçları tablo, gösterge paneli veya yönetici özeti biçiminde sunulabilir.

Güvenlik ve mahremiyet nedenleriyle modelin yayımlanması için ham üretim verisi gerekmemektedir. Yalnızca toplulaştırılmış sayımlar, normalize edilmiş skorlar ve anonimleştirilmiş örnek açıklamalar paylaşılabılır. Bu durum modeli akademik çalışma, kurum içi raporlama ve kontrollü laboratuvar değerlendirmeleri için uygun hale getirmektedir.

VII. SONUÇ

Bu bildiride SIEM telemetrisi ve tehdit istihbaratı kullanılarak saldırı yüzeyi görünürlüğünü ölçmeye yönelik açıklanabilir graf tabanlı bir model sunulmuştur. Önerilen yaklaşım, varlık envanterini, Wazuh alarmlarını, CTI

nesnelerini ve MITRE ATT&CK tekniklerini ilişkisel bir graf üzerinde birleştirerek güvenlik görünürlüğünü sayısallaştırmaktadır. Log kapsama, kritik varlık kapsamı, MITRE algılama kapsamı, CTI zenginleştirme ve telemetri güncelliği metrikleri tek bir görünürlük skorunda bir araya getirilmiştir.

Kavram kanıtlama senaryosu, graf tabanlı füzyonun parçalı güvenlik kanıtlarını yorumlanabilir bir görünürlük değerlendirmesine dönüştürebildiğini göstermektedir. Model yalnızca nihai skor üretmek yerine, görünürlüğü azaltan varlıkları, telemetri eksikliklerini ve kapsanmayan teknikleri açıklayabilmektedir. Gelecek çalışmalarda modelin daha büyük veri setleriyle değerlendirilmesi, ağırlıkların uzman görüşü veya öğrenme tabanlı yöntemlerle uyarlanması ve LLM destekli açıklama katmanının sistematik olarak ölçülmesi hedeflenmektedir.

TEŞEKKÜR

Bu çalışma akademik konferans başvurusu için araştırma taslağı olarak hazırlanmıştır. Kavram kanıtlama bölümündeki laboratuvar değerleri sentetik telemetriye dayanmakta olup herhangi bir hassas üretim verisi içermemektedir.

KAYNAKLAR

- [1] The MITRE Corporation, "Enterprise Matrix," MITRE ATT&CK. Accessed: Jun. 21, 2026. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>
- [2] Wazuh, "MITRE ATT&CK framework - Data analysis," Wazuh Documentation. Accessed: Jun. 21, 2026. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/ruleset/mitre.html>
- [3] OASIS Cyber Threat Intelligence TC, "STIX Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [4] K. Dempsey, N. Chawla, A. Johnson, R. Johnston, A. Jones, A. Orebaugh, M. Scholl, and K. Stine, "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations," NIST Special Publication 800-137, 2011.
- [5] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," NIST Cybersecurity White Paper, 2024.
- [6] B. Al-Sada, A. Sadighian, and G. Oligeri, "MITRE ATT&CK: State of the Art and Way Forward," arXiv:2308.14016, 2023.
- [7] H. Manocha, A. Srivastava, C. Verma, R. Gupta, and B. Bansal, "Security Assessment Rating Framework for Enterprises using MITRE ATT&CK Matrix," arXiv:2108.06559, 2021.
- [8] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, "A review of knowledge graph application scenarios in cyber security," arXiv:2204.04769, 2022.
- [9] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in Proc. IEEE Symposium on Security and Privacy, 2010, pp. 305-316.
- [10] V. Mavroeidis and S. Bromander, "Cyber threat intelligence model: An evaluation of taxonomies, sharing standards, and ontologies within cyber threat intelligence," in Proc. 2017 European Intelligence and Security Informatics Conference, 2017, pp. 91-98.
- [11] OASIS Cyber Threat Intelligence TC, "TAXII Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html>
- [12] M. Ussath, D. Jaeger, F. Cheng, and C. Meinel, "Advanced persistent threats: Behind the scenes," in Proc. 2016 Annual Conference on Information Science and Systems, 2016, pp. 181-186.